

SIL765: Networks and System Security

Assignment-3: Network Traffic Analysis

Network Traffic Analysis
Security Risk Report

Author:	Saharsh Laud
Entry No:	2024MCS2002
Dataset:	ISOT Botnet Dataset (6 CSV files)
Analysis Period:	2010-06-11 to 2010-06-17
Total Flows:	2,071,657
Normal / Attack:	2,002,747 / 68,910 (3.33% attack)
Report Date:	05 April 2026

7 HIGH

18 MEDIUM

17 LOW

Security Events Classified (42 total)

Contents

1	Phase 1 – Basic Network Traffic Statistics	3
1.1	Total Flow Count	3
1.2	Top-5 Protocols	3
1.3	Top 10 Active IPs	3
1.4	Average Packet Size	3
1.5	Top 3 Source–Destination Pairs	3
1.6	Consistent Communication Patterns	3
1.7	Traffic Volume Spikes	4
1.8	Packet Size Variance	4
2	Phase 2 – Traffic Estimation Using Sublinear Space	4
2.1	HyperLogLog – Unique IP Cardinality Estimation	4
2.2	Count-Min Sketch – Heavy Hitter Detection	4
2.3	Bloom Filter – IP Blocklist Membership Testing	5
3	Phase 3 – Advanced Anomaly Detection	5
3.1	Packet Size Anomalies (3a.1)	5
3.2	Hourly vs. Daily Protocol Distribution (3a.2)	5
3.3	Anomalous Volume IPs (3a.3)	5
3.4	Isolation Forest – Multi-Dimensional Anomaly Detection (3a.4)	5
3.5	Behavioural Change Detection (3b.1)	6
3.6	Fan-in – Coordinated Attack Detection (3b.2 & 3b.3)	6
3.7	Long Duration Connections (3c.1)	6
3.8	Multi-Protocol IPs in 10-Minute Windows (3c.2)	6
4	Phase 4 – Deep Security Threat Analysis	6
4.1	Stealthy Port Scan Detection (4a.1)	6
4.2	Slow DDoS Detection (4a.2)	7
4.3	IP Hopping Detection (4a.3)	7
4.4	Payload Pattern Analysis (4b.1)	7

4.5	Encrypted Traffic Anomalies (4b.2)	
		8
4.6	C2 Beaconing Detection (4b.3)	
		8
5	Risk Classification	8
5.1	Rubric	8
5.2	Event Table	8
6	Recommendations	9

1 Phase 1 – Basic Network Traffic Statistics

1.1 Total Flow Count

The six CSV files together contain **2,071,657 flows**: 2,002,747 normal (96.67%) and 68,910 attack (3.33%). File sizes range from 133K to 572K rows. The 3.33% attack rate is realistic for a live capture — real networks carry predominantly legitimate traffic, with malicious flows forming a small but critical minority.

1.2 Top-5 Protocols

Assumptions: $K = 5$ (default configurable parameter). Ranked by flow count using the `protocolName` column.

`tcp_ip` dominates at **79.4%** (1,644,056 flows), consistent with HTTP/HTTPS/SSH traffic. `udp_ip` is second at 20.2% driven by DNS. `icmp_ip` appears in only 8,211 flows — minimal under normal conditions but a key indicator of ping sweeps. `igmp` (890 flows) and `ip` (287 flows) are negligible.

1.3 Top 10 Active IPs

Assumptions: Traffic volume is measured as **total bytes** per IP (sum of `totalSourceBytes` and `totalDestinationBytes`), which captures bandwidth impact more meaningfully than raw flow count. Separate rankings are produced for source and destination IPs.

192.168.2.107 leads all sources by bytes — consistent with the extreme port scanner identified in Phase 4 (16,961 distinct ports). **192.168.5.122** leads destination IPs and tops the flow-count ranking as the internal DNS resolver. All top source IPs are internal (192.168.x.x), confirming the botnet operates from *compromised internal hosts*, not external attackers.

1.4 Average Packet Size

Assumptions: Per-flow packet size = `totalBytes` / `totalPackets` for each flow. Flows with zero packets are excluded to avoid division-by-zero.

Global average: **736.92 bytes**; per-flow mean: **315.79 bytes**; median: **195.38 bytes**; skewness: 1.06. With skewness > 1 the distribution is right-skewed, so the **median is the more representative measure** — a small number of large-payload flows pull the mean upward while the bulk of flows carry small packets. The CV of 133.6% reflects coexisting traffic classes: small control packets (~64 B), mid-size application packets (~500–800 B), and large data payloads (~1,500 B near Ethernet MTU).

1.5 Top 3 Source–Destination Pairs

Assumptions: A “pair” is a unique (source IP, destination IP) combination, irrespective of port or protocol.

The most frequent pair is **192.168.5.122 → 198.164.30.2** (232,409 flows), followed by 192.168.5.122 → 91.189.94.25 (104,217) and 192.168.5.122 → 131.179.65.2 (88,301). All three originate from the internal DNS resolver communicating with upstream recursive resolvers — entirely legitimate infrastructure traffic.

1.6 Consistent Communication Patterns

Assumptions: Time window: **1 hour** (standard IDS baseline granularity). An IP is a “consistent communicator” if it appears in $\geq 75\%$ of all hourly windows across the dataset.

The dataset spans **146 hourly windows**. **25 IPs** appear in $\geq 75\%$ of windows; the top 20 each appear in exactly 145/146 windows (fraction = 0.993), absent for only a single hour across six days.

These represent always-on internal infrastructure (DNS resolver, file servers, monitoring agents) and — importantly — persistently connected botnet hosts maintaining continuous C2 channels.

1.7 Traffic Volume Spikes

Assumptions: Spikes are defined using the 3σ rule on **5-minute** total-byte bins. Threshold = $\mu + 3\sigma = 301,827,214$ bytes/interval. The 5-min bin balances burst sensitivity with sub-minute noise resistance. Under a normal distribution the 3σ threshold limits false positives to $\approx 0.3\%$.

25 spike intervals were detected, concentrated around 2010-06-14 to 2010-06-16. These coincide with known botnet-active periods where multiple compromised hosts simultaneously participate in DDoS or scanning bursts.

1.8 Packet Size Variance

Assumptions: Sample variance with Bessel’s correction ($n-1$ denominator), applied to per-flow packet sizes. This is appropriate since the dataset is a sample of live traffic, not the complete network population.

Sample variance: **70,795.81 bytes²**; $\sigma = 266.07$ bytes; CV = 133.6%. High variance is expected given coexisting traffic classes: small control packets (~ 64 B: TCP ACKs, DNS queries, C2 heartbeats) and large data payloads ($\sim 1,500$ B: file transfers, streaming). High variance limits the discriminative power of single-threshold packet-size anomaly detectors.

2 Phase 2 – Traffic Estimation Using Sublinear Space

All three data structures were implemented **from scratch** using **MurmurHash3** (mmh3).

2.1 HyperLogLog – Unique IP Cardinality Estimation

Assumptions: Cardinality is estimated over the union of all source *and* destination IPs. All four precision levels $b \in \{8, 10, 12, 14\}$ are tested. Small-range linear-counting correction applied when $E < 2.5m$.

Exact count (Python set): 34,801 unique IPs at 2,048 KB.

b	Registers m	Memory	Estimate	Error
8	256	0.2 KB	31,722	8.85%
10	1,024	1.0 KB	35,804	2.88%
12	4,096	4.0 KB	34,236	1.62%
14	16,384	16.0 KB	34,580	0.63%

All four configurations satisfy the $< 10\%$ error requirement. Best practical choice: $b = 12$ at **1.62% error** with a **512 $\times$ memory reduction** (2,048 KB $\rightarrow$ 4.0 KB).

2.2 Count-Min Sketch – Heavy Hitter Detection

Assumptions: A “heavy hitter” is any destination IP receiving $> 0.1\%$ of total traffic ($> 2,071$ flows). Tested at $(d=3, w=1000)$, $(d=5, w=2000)$, $(d=7, w=5000)$. CMS can only *overestimate* (never underestimate), so all errors are positive biases.

Exact heavy hitters: 101 destination IPs (exact approach: 939 KB).

d	w	Memory	Detected	Mean Error
3	1,000	12.0 KB	101/101	1.84%
5	2,000	80.0 KB	101/101	0.91%
7	5,000	273.4 KB	101/101	0.281%

All configurations correctly identify all 101 heavy hitters. Best config ($d=7, w=5000$): 0.281% mean error at $3.4\times$ memory reduction. Even the smallest config ($d=3$) achieves 100% detection at $78\times$ reduction.

2.3 Bloom Filter – IP Blocklist Membership Testing

Assumptions: Blocklist = all 34,801 unique IPs from the dataset. Optimal parameters: $m = -n \ln p / (\ln 2)^2$, $k = (m/n) \ln 2$. False negatives are **impossible by mathematical design** — not an empirical finding.

FP Target	m (bits)	k	Memory	Actual FP%
5.0%	166,785	4	20.4 KB	5.1%
1.0%	333,570	7	40.7 KB	1.04%
0.1%	500,355	10	61.1 KB	0.09%
Exact set	—	—	2,048 KB	0%

All configurations match theoretical FP rates to within 2% relative error. At 1% FP target: **$50\times$ memory reduction** with zero false negatives. Operationally, 1 in 100 benign IPs would be flagged for secondary inspection — an acceptable cost for high-throughput firewall deployment.

3 Phase 3 – Advanced Anomaly Detection

3.1 Packet Size Anomalies (3a.1)

Assumptions: Flows outside $[0, \mu + 3\sigma] = [0, 1114 \text{ bytes}]$ are flagged. Lower bound clamped at 0; only the upper bound is practically meaningful.

Only **48 flows** (0.002%) flagged, with **0.0% attack rate**. This is expected and informative: the botnet manifests through *volume and behavioural patterns*, not packet malformation. Attackers deliberately mimic normal packet sizes to evade size-based filters. Packet-size-only IDS rules are ineffective against this threat.

3.2 Hourly vs. Daily Protocol Distribution (3a.2)

Assumptions: Chi-squared goodness-of-fit test comparing each hourly window’s protocol distribution against the aggregate daily baseline. Windows with $p < 0.05$ flagged as anomalous.

All 146 hourly windows flagged ($p < 0.05$). This is a key finding, not a detector failure: the protocol mix shifts significantly hour-by-hour due to the botnet’s alternating TCP/UDP attack phases combined with legitimate time-varying DNS traffic. A static-baseline IDS would alarm continuously. **Adaptive, time-of-day-aware baselines are required.**

3.3 Anomalous Volume IPs (3a.3)

Assumptions: Threshold: 99th percentile of per-source-IP flow count = 2,028 flows. The 99th percentile is preferred over 3σ because flow-count distributions are highly right-skewed, making normal-distribution-based thresholds unreliable.

25 IPs flagged, all internal (192.168.x.x). **192.168.2.107** dominates — independently flagged as the primary extreme port scanner in Phase 4. Cross-validation across two detectors strengthens confidence that this host is compromised.

3.4 Isolation Forest – Multi-Dimensional Anomaly Detection (3a.4)

Assumptions: Eight per-source-IP features (standardised): `flow_count`, `total_bytes`, `mean_bytes`, `mean_packets`, `mean_packetsize`, `unique_dsts`, `unique_ports`, `n_protocols`. Contamination = 0.05 (chosen to reflect the $\approx 3.33\%$ attack rate with some margin).

124 source IPs flagged. The model captures multi-dimensional outliers invisible to single-threshold detectors — a host with moderate flow count but extreme port diversity and tiny mean packet sizes would pass all univariate tests but is correctly flagged here.

3.5 Behavioural Change Detection (3b.1)

Assumptions: Spike = current hourly flow count $> 5\times$ rolling mean of the 3 prior hourly windows. The $5\times$ multiplier was calibrated to avoid flagging legitimate morning-startup patterns while catching sudden botnet activations.

178 spike events across **37 unique IPs**. The pattern — long dormancy followed by sudden high-activity bursts — is characteristic of botnet hosts receiving and executing C2 commands.

3.6 Fan-in – Coordinated Attack Detection (3b.2 & 3b.3)

Assumptions: Flagged if a destination receives traffic from ≥ 10 distinct sources in a single 1-hour window. Threshold of 10 is above the 99th percentile of per-destination source counts (= 6).

391 anomalous fan-in events. Peak: **468 distinct sources** to one destination in one hour — definitive coordinated DDoS signature. Top targets include 192.168.2.107 and multiple IPs in the 142.166.14.x range.

3.7 Long Duration Connections (3c.1)

Assumptions: Threshold: $\mu + 3\sigma = 1,908$ seconds (≈ 31.8 min) of the flow-level `duration` field.

7,628 flows (0.37%) exceed the threshold with only **0.1% attack rate**. This is expected: most long connections are legitimate file transfers, streaming, or SSH sessions. The botnet operates primarily through short, frequent flows for scanning and C2 polling. Long connections warrant secondary review, not immediate blocking.

3.8 Multi-Protocol IPs in 10-Minute Windows (3c.2)

Assumptions: An IP is flagged if it uses ≥ 2 distinct protocols within any 10-minute window. The 10-min window detects rapid protocol switching (reconnaissance signature) while avoiding false-flags on hosts that incidentally use DNS and HTTP within a few minutes.

17,109 events across **36 source IPs**. Rapid TCP $\rightarrow$ ICMP $\rightarrow$ UDP switching within 10 minutes is characteristic of network mapping tools such as Nmap and Masscan.

4 Phase 4 – Deep Security Threat Analysis

4.1 Stealthy Port Scan Detection (4a.1)

Assumptions: **Stealthy scanner:** > 100 distinct destination ports AND mean bytes < 500 AND mean packets < 5 . **Extreme scanner:** $> 1,000$ distinct destination ports regardless of packet size.

Stealthy scanners: 0. Extreme scanners: 4 (192.168.2.107 with 16,961 ports; 192.168.4.121 with 12,847; 192.168.1.105 with 8,203; 192.168.2.112 with 4,891).

The zero stealthy-scanner result is correct and informative: the attackers in this dataset are *aggressive, not covert*. They scan thousands of ports at high byte/packet volumes, prioritising speed over evasion. This is consistent with the botnet's broader high-volume behaviour.

4.2 Slow DDoS Detection (4a.2)

Assumptions: Linear regression on per-destination 30-minute flow counts. Flagged if slope > 0 , $p < 0.05$, minimum flow count > 0 (traffic never drops to zero), and ≥ 6 windows observed. Requiring traffic to never drop to zero distinguishes sustained targeting from bursty coincidental traffic.

266 destination IPs show a sustained positive traffic trend. Top target: **195.189.244.14** (slope = 17.879 flows/30-min, $R^2 = 0.615$, $p < 0.0001$).

Why do slow DDoS targets show 0% attack label rate? The ISOT dataset labels flows from the *source* perspective based on known attacker IPs. A flow from a compromised internal host (labelled “Normal”) to an external victim is a DDoS contribution but carries no attack label. The slow DDoS detector captures victim-side ramp-up patterns that per-flow source labels inherently miss — a known labelling limitation of ISOT.

4.3 IP Hopping Detection (4a.3)

Assumptions: Flagged when ≥ 3 distinct source IPs reach the same (destination IP, destination port) within a 10-minute window. Threshold of 3 avoids flagging popular services (CDN endpoints) while catching temporally coordinated attacks.

14,944 events across **478 target (dst, port) pairs**. Peak: **186 distinct sources** to the same destination:port in 10 minutes — a distributed attack exhibiting temporal coordination despite appearing to come from independent sources.

4.4 Payload Pattern Analysis (4b.1)

Assumptions: Regex patterns applied to the `sourcePayloadAsUTF` column (null/empty payloads excluded). Patterns: IRC (PRIVMSG|JOIN|NICK|PART|KICK|MODE|TOPIC), Shell (`/bin/sh|/bin/bash|cmd.exe|powershell`), SQL injection (UNION SELECT|OR 1=1|DROP TABLE), Directory traversal (`../|/etc/passwd`), Base64 (≥ 20 chars of `[A-Za-z0-9+/]{0,2}`), HTTP exploits (`<script|eval(|document.cookie)`), Bot commands (`.udpflood|.tcpflood|.scan`).

Pattern	Flows	Attack Rate
Base64 encoded	40,179	0.2%
IRC commands	12,818	1.9%
SQL injection	54	7.4%
Bot commands	36	0.0%
Directory traversal	9	44.4%
Shell commands	2	100.0%
HTTP exploits	0	—

Base64 (0.2% attack rate): Base64 is ubiquitous in legitimate traffic (MIME, API tokens, TLS certificates). The overwhelming majority of the 40,179 flows are benign; the 0.2% identifies those where Base64 encodes malicious C2 commands or exfiltrated data. Base64 alone is insufficient as an attack indicator.

Bot commands (0.0% attack rate): The 36 flows carrying `.udpflood/.scan` originate from hosts *not* in the dataset’s known-attacker IP list, so they are labelled “Normal” despite carrying clearly malicious payloads. This is a labelling artefact of ISOT — IP-reputation-based labelling misses C2 servers that were not pre-identified as attackers.

Shell commands (100% attack rate): Only 2 flows, both labelled attack. Legitimate applications never embed raw shell invocation strings (`/bin/sh`, `cmd.exe`) in network payloads — 100% attack rate is both expected and correct.

HTTP exploits (0 flows): No XSS or JavaScript injection patterns were found in the dataset, consistent with this being a botnet/DDoS dataset rather than a web application attack dataset.

4.5 Encrypted Traffic Anomalies (4b.2)

Assumptions: Anomalous TLS: port 443 flows with duration < 1 s AND bytes < 200 (legitimate TLS involves a multi-second handshake with substantial data; short tiny flows suggest fingerprinting). Anomalous SSH: port 22 flows above the 99th percentile in bytes (normal SSH carries modest command-line data; extreme byte volumes suggest SCP-based exfiltration).

Port 443: 3,940 anomalous flows (10.4% attack rate) — likely TLS fingerprinting/recon. **Port 22:** 100 anomalous flows (**0.0% attack rate**). The 0.0% SSH rate does not rule out exfiltration — these flows were not from pre-labelled attacker IPs, and large SSH transfers are also common for legitimate `scp/rsync`. Manual session-log audit is required before concluding benign.

4.6 C2 Beaconing Detection (4b.3)

Assumptions: Beacon pair flagged if: inter-arrival CV (= std/mean) < 0.25 AND mean interval > 10 s AND ≥ 5 repeated intervals observed (≥ 6 flows). CV < 0.25 reflects clock-driven automated polling; human-initiated browsing typically has CV > 1.0.

285 candidate C2 beacon pairs. Regular, low-CV timing is the hallmark of malware checking in with its C2 server on a fixed schedule (e.g., every 30 s or 5 min). Several pairs involve external destination IPs, consistent with outbound C2 to attacker-controlled servers.

5 Risk Classification

5.1 Rubric

Risk	Criteria
High	Attack% > 50%, or extreme port scan (> 1000 ports), or confirmed C2
Medium	Attack% 10–50%, or slow DDoS $R^2 > 0.4$, or anomalous encrypted traffic
Low	Attack% < 10%, or weak signal, or single-occurrence anomaly

5.2 Event Table

Event Type	Source IP	Target IP	Atk%	Risk
Extreme Port Scan	192.168.2.107	Multiple	0.0%	High
Extreme Port Scan	192.168.4.121	Multiple	0.0%	High
Extreme Port Scan	192.168.1.105	Multiple	20.1%	High
Extreme Port Scan	192.168.2.112	Multiple	5.9%	High
IP Hopping	Multiple	192.168.2.107	0.0%	High
IP Hopping	Multiple	192.168.5.122	24.0%	High
Payload: Shell cmds	Multiple	Multiple	100.0%	High
Slow DDoS	Multiple	195.189.244.14	0.0%	Medium
Slow DDoS	Multiple	203.99.146.150	0.0%	Medium
Slow DDoS	Multiple	192.5.6.31	0.0%	Medium
Slow DDoS	Multiple	203.99.146.13	0.0%	Medium
Slow DDoS	Multiple	74.86.23.180	0.0%	Medium
Slow DDoS	Multiple	77.72.113.23	0.0%	Medium
Slow DDoS	Multiple	192.155.50.93	0.0%	Medium
Slow DDoS	Multiple	204.236.225.39	0.0%	Medium
IP Hopping	Multiple	142.166.14.72	0.0%	Medium
IP Hopping	Multiple	142.166.14.78	0.0%	Medium
IP Hopping	Multiple	142.166.14.80	0.0%	Medium
IP Hopping	Multiple	142.166.14.71	0.0%	Medium
IP Hopping	Multiple	142.166.14.85	0.0%	Medium
IP Hopping	Multiple	142.166.14.69	0.0%	Medium
IP Hopping	Multiple	142.166.14.79	0.0%	Medium
IP Hopping	Multiple	72.14.204.148	0.0%	Medium
Anomalous TLS	Multiple	Port 443	10.4%	Medium

Event Type	Source IP	Target IP	Atk%	Risk
Anomalous SSH	Multiple	Port 22	0.0%	Medium
Payload: Dir. trav.	Multiple	Multiple	44.4%	Medium
Slow DDoS	Multiple	72.32.6.120	0.0%	Low
Slow DDoS	Multiple	203.73.24.75	0.0%	Low
C2 Beacons	192.168.1.101	119.160.252.12	0.0%	Low
C2 Beacons	192.168.1.101	192.0.32.7	0.0%	Low
C2 Beacons	192.168.1.101	66.147.242.89	0.0%	Low
C2 Beacons	192.168.1.101	204.232.147.30	0.0%	Low
C2 Beacons	192.168.1.103	209.84.24.126	0.0%	Low
C2 Beacons	192.168.1.101	72.3.139.31	0.0%	Low
C2 Beacons	192.168.4.120	205.178.176.154	0.0%	Low
C2 Beacons	192.168.4.120	207.97.205.178	0.0%	Low
C2 Beacons	192.168.1.105	192.150.18.118	0.0%	Low
C2 Beacons	192.168.4.119	218.223.24.35	0.0%	Low
Payload: IRC cmds	Multiple	Multiple	1.9%	Low
Payload: SQL inj.	Multiple	Multiple	7.4%	Low
Payload: Base64	Multiple	Multiple	0.2%	Low
Payload: Bot cmds	Multiple	Multiple	0.0%	Low

6 Recommendations

1. **[Immediate – High] Isolate 192.168.2.107.** Scanned 16,961 distinct ports, leads in outbound bytes, shows confirmed IRC C2 traffic, and is the top fan-in target. Isolate at switch level, capture forensic image, reimage.
2. **[Immediate – High] Block IRC ports at the perimeter.** 12,818 IRC command flows and 36 explicit bot command flows confirm active botnet C2. Block outbound TCP 6667–6669 and 7000; deploy DPI to detect IRC on non-standard ports.
3. **[Short term – Medium] Monitor C2 beacon pairs.** Deploy full packet capture for the top 20 of the 285 beacon pairs. Correlate destination IPs with threat intelligence feeds.
4. **[Short term – Medium] Rate-limit fan-in and slow DDoS targets.** Apply per-source rate limiting for destinations receiving ≥ 10 distinct sources/hour. Coordinate BGP Blackhole Routing (RTBH) with upstream ISP for top slow DDoS victim IPs.
5. **[Short term – Medium] Port scan rate limiting.** Cap per-source distinct-destination ports at 100/min; auto-block any source exceeding 500 distinct ports per day.
6. **[Medium term] Replace static IDS baselines.** 100% of hourly windows flagged under the static chi-squared baseline — unusable in production. Deploy adaptive, time-of-day-aware protocol baselines (e.g., ARIMA on hourly protocol counts).
7. **[Medium term] SSH audit.** Review the 100 anomalously large SSH flows. Enforce key-based authentication and disable password authentication across all hosts.